

RAPPORT TP SIEM & SOC

Scénario : Construire, opérer et analyser le premier niveau défensif d'un Security Operations Center à travers un scénario bancaire réaliste

Etudiant : DIAWARA Nana
Filière : 2 ème année cycle ingénieur - Cyber sécurité
Encadrant : Professeur AMAMOU AHMED
Rôle : Simulation Analyste SOC Tier 1
Outils déployés : pfSense, Suricata, Wazuh, Filebeat, Elastic Stack

Construction et opération du premier niveau défensif d'un SOC

Année académique : 2025-2026

Table des matières

1	Introduction au SIEM	2
1.1	Contexte et Enjeux	2
1.2	Objectifs du Rapport	2
2	Architecture mise en place	2
3	Description des agents	3
3.1	Suricata (NIDS)	3
3.2	Wazuh (HIDS)	3
3.3	Filebeat (Log Shipper)	3
4	Collecte et corrélation des logs	4
4.1	Pipeline de Collecte	4
4.2	Normalisation ECS (Elastic Common Schema)	4
4.3	Exemples de Logs Bruts Collectés	4
5	Création des alertes	5
5.1	Alertes Natives Déclenchées	5
5.2	Création d'une Règle de Corrélation EQL	5
6	Analyse d'incidents	6
6.1	Chronologie de l'Attaque (Kill Chain)	6
6.2	Indicateurs de Compromission (IoC)	6
6.3	Décision et Triage SOC Tier 1	7
7	Dashboards Kibana / Wazuh / Zabbix / Shuffle	7
7.1	Dashboard Kibana SIEM	7
7.2	Dashboard Wazuh	7
7.3	Perspective Zabbix (Supervision Infrastructure)	8
7.4	Perspective Shuffle (SOAR)	8
8	Conclusion	8
8.1	Bilan Technique	8
8.2	Leçons Apprises et Recommandations	9

1 Introduction au SIEM

1.1 Contexte et Enjeux

Un Security Operations Center (SOC) est l'unité organisationnelle et technique chargée de surveiller en permanence la sécurité d'un système d'information. Pour une entité comme **SecureBank SA** (banque en ligne marocaine gérant 300 000 comptes), le SOC représente la dernière ligne de défense avant qu'une intrusion ne se transforme en brèche de données financières.

Le SIEM (Security Information and Event Management) est le cerveau de cette opération. Sans lui, un analyste serait submergé par des centaines de milliers de logs hétérogènes. Le SIEM assure la collecte, la normalisation, la corrélation et l'alerte en temps réel, réduisant le temps moyen de détection (MTTD) de plusieurs mois à quelques minutes.

1.2 Objectifs du Rapport

Ce document synthétise la mise en place opérationnelle de l'infrastructure de détection de SecureBank SA. Il détaille l'architecture déployée, les agents de collecte, les mécanismes de corrélation via le schéma ECS (Elastic Common Schema), la création de règles d'alerte (notamment EQL), et l'analyse complète d'un incident simulé en trois phases (Reconnaissance, Brute-force, Injection SQL). Il aborde également la vision des dashboards de supervision (Kibana, Wazuh, et les perspectives Zabbix/Shuffle).

2 Architecture mise en place

L'infrastructure de SecureBank SA est segmentée en trois zones de sécurité distinctes pour limiter la propagation latérale en cas de compromission.

- **ZONE WAN** : Représente Internet. C'est la zone d'origine de l'attaquant (nœud de sortie Tor 185.220.101.47).
- **ZONE DMZ (192.168.50.0/24)** : Héberge les services exposés :
 - Portail Web (192.168.50.10) : Apache, PHP, SSH.
 - API de Paiement (192.168.50.20) : Node.js, REST, port 3000.
 - Reverse Proxy / WAF (192.168.50.5).
- **ZONE LAN (10.0.10.0/24)** : Zone critique hébergeant :
 - Base de données Oracle (10.0.10.5).
 - Serveur SOC SIEM (192.168.50.100) : Elasticsearch, Kibana, Wazuh Manager.

Le trafic est filtré par deux pare-feux pfSense. Le premier (FW-DMZ) héberge également le moteur **Suricata** en mode IDS passif (analyse par copie miroir du trafic) pour éviter tout blocage intempestif de virements légitimes (faux positifs).

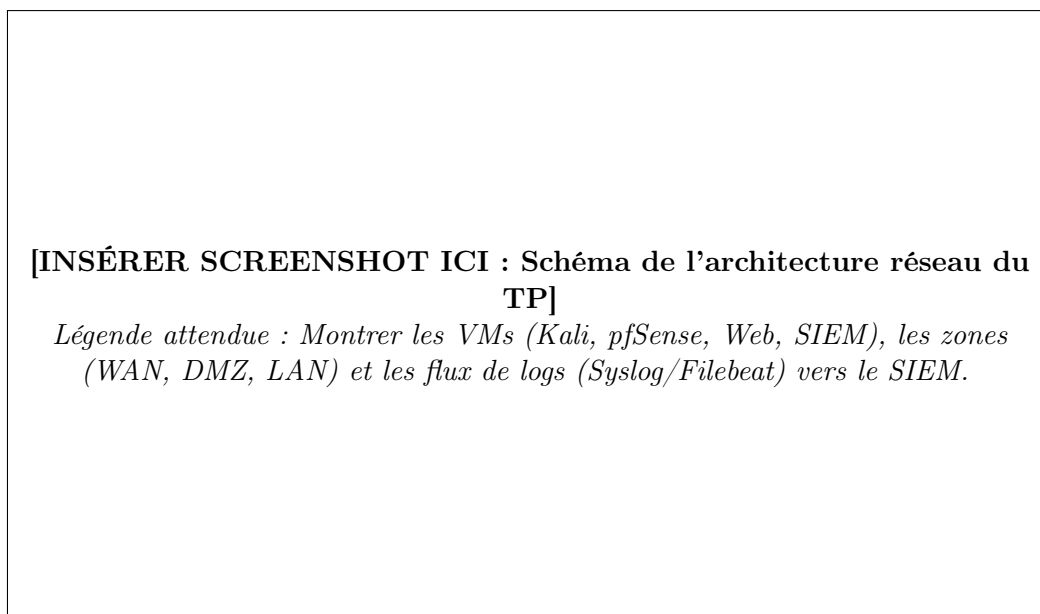


FIGURE 1 – Cartographie de l'architecture SOC SecureBank SA

3 Description des agents

Pour assurer une visibilité complète (réseau et hôte), plusieurs agents et sondes ont été déployés :

3.1 Suricata (NIDS)

Installé en tant que package sur pfSense. Il inspecte chaque paquet réseau et le compare aux signatures *Emerging Threats Open* (ET-Open). Il est configuré en mode **IDS passif** (Séance 1) : il génère des alertes au format JSON (`eve.json`) sans bloquer le trafic, garantissant une latence nulle et aucun risque de coupure de service bancaire.

3.2 Wazuh (HIDS)

Agent léger déployé sur chaque serveur de la DMZ (ex : `web01-securebank`). Il assure trois fonctions critiques :

1. **Log Analysis** : Surveillance des journaux système (ex : `/var/log/auth.log`) pour détecter les échecs d'authentification.
2. **FIM (File Integrity Monitoring)** : Détection de toute modification non autorisée des fichiers sensibles (ex : `/etc/passwd`).
3. **Active Response** : (Prévu pour la Séance 3) Exécution automatique de scripts (ex : `iptables DROP`) en réaction à une alerte.

3.3 Filebeat (Log Shipper)

Agent de la stack Elastic déployé sur les serveurs. Il surveille les fichiers de logs en temps réel (mécanisme de type `tail -f` intelligent), applique une normalisation préliminaire via des modules dédiés (Suricata, Apache, System), et transfère les données vers Elasticsearch avec une latence inférieure à la seconde.

4 Collecte et corrélation des logs

4.1 Pipeline de Collecte

Les logs bruts arrivent dans des formats hétérogènes. Le pipeline mis en place est le suivant :

1. **pfSense** envoie ses logs de filtrage via Syslog UDP (port 514) vers le serveur SIEM.
2. **Filebeat** lit le fichier `eve.json` de Suricata et les logs Apache locaux.
3. **Wazuh Manager** reçoit les événements de l'agent hôte et les forward à Elasticsearch via une intégration native.
4. **Elasticsearch** indexe l'ensemble des données (ex : `securebank-suricata-2026.04.11`).

4.2 Normalisation ECS (Elastic Common Schema)

Sans normalisation, l'adresse IP source s'appellerait `src_ip` dans Suricata, `client_ip` dans Apache, et `remote_addr` dans nginx. L'ECS impose un langage commun. Après traitement, tous les logs partagent les mêmes champs :

- `source.ip` : "185.220.101.47"
- `destination.ip` : "192.168.50.10"
- `event.module` : "suricata" ou "wazuh"
- `event.outcome` : "failure"

4.3 Exemples de Logs Bruts Collectés

```
Apr 11 06:47:23 pfsense filterlog: 4,,,block,WAN,in,185.220.101.47  
->192.168.50.10,TCP,SYN
```

Listing 1 – Log pfSense (Filtrage)

```
{ "timestamp": "2026-04-11T06:47:23", "event_type": "alert",  
  "src_ip": "185.220.101.47", "alert": {"signature": "ET SCAN Nmap", "  
    severity": 1} }
```

Listing 2 – Log Suricata (eve.json)

```
Apr 11 07:03:11 web01 sshd[4421]: Failed password for admin from  
185.220.101.47 port 58432
```

Listing 3 – Log Wazuh (auth.log)

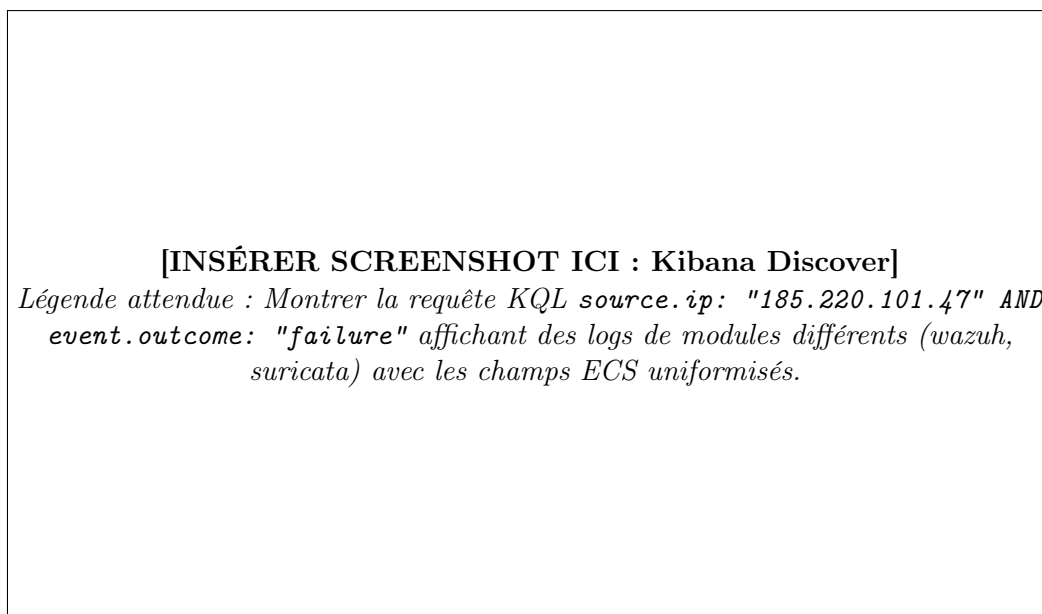


FIGURE 2 – Vue unifiée des logs normalisés via ECS dans Kibana Discover

5 Création des alertes

Le SIEM génère des alertes enrichies pour faciliter la prise de décision du Tier 1. Trois alertes natives ont été déclenchées lors du scénario, suivies de la création d'une règle de corrélation avancée.

5.1 Alertes Natives Déclenchées

Heure	Source	Signature / Règle	Sévérité
06 :47	Suricata	ET SCAN Nmap OS Detection	High
07 :03	Wazuh	Rule 5712 : SSH brute force attack	Critical
07 :15	Suricata	ET SQL SQL Injection Attack	Critical

TABLE 1 – Synthèse des alertes natives générées par l'attaque

5.2 Création d'une Règle de Corrélation EQL

Une alerte isolée peut être du bruit. Pour détecter la *kill chain* complète, une règle de corrélation d'événements (EQL - Event Query Language) de type **sequence** a été créée dans Kibana Security.

```
sequence by source.ip with maxspan=30m
/* Phase 1 & 2 : Multiples checks d'authentification SSH */
[authentication where event.outcome == "failure" and destination.port == 22]
[authentication where event.outcome == "failure" and destination.port == 22]
[authentication where event.outcome == "failure" and destination.port == 22]

/* Phase 3 : Tentative d'exploitation SQLi détectée par Suricata */
```

```
[network where event.module == "suricata" and suricata.eve.alert.
category like "*sql*"]
```

Listing 4 – Règle EQL "SecureBank - Kill Chain Recon+BF+SQLi"

Paramètres de la règle :

- **Name** : SecureBank — Kill Chain Recon+BF+SQLi
- **Severity** : Critical
- **Risk Score** : 95
- **MITRE ATT&CK** : T1046, T1110.001, T1190
- **Schedule** : Every 5 min / Last 35 min

[INSÉRER SCREENSHOT ICI : Kibana Security → Rules → Create Rule]

Légende attendue : Montrer l'interface de création de la règle EQL avec le code et les paramètres (Severity : Critical, Risk Score : 95).

FIGURE 3 – Configuration de la règle de détection EQL dans Kibana

6 Analyse d'incidents

6.1 Chronologie de l'Attaque (Kill Chain)

L'investigation via l'onglet *Timeline* de Kibana a permis de reconstituer l'attaque sur une fenêtre de 28 minutes :

1. **06 :47 (Reconnaissance - MITRE T1046)** : Scan Nmap complet des ports 22, 80, 443, 3000, 8080 depuis l'IP Tor 185.220.101.47.
2. **07 :03 (Accès Initial - MITRE T1110.001)** : 247 tentatives d'authentification SSH en 12 minutes ciblant l'utilisateur `admin` sur le serveur 192.168.50.10.
3. **07 :15 (Exploitation - MITRE T1190)** : Requêtes POST malformées avec payloads SQL (`' OR '1'='1`) ciblant l'endpoint `/api/login`.

6.2 Indicateurs de Compromission (IoC)

- **IP Source** : 185.220.101.47 (Nœud de sortie Tor, Pays-Bas).
- **Cibles** : 192.168.50.10 (Port 22), 192.168.50.20 (Port 3000).
- **User-Agent / Payload** : `' OR '1'='1` (Signature SQLi classique).

6.3 Décision et Triage SOC Tier 1

Conformément à la matrice de décision du SOC :

- **Classification** : Vrai Positif. L'IP est malveillante et la séquence d'actions est cohérente avec une attaque réelle.
- **Priorité : P1 (Critique)**. L'API de paiement et les données Oracle sont directement menacées.
- **Action** : Escalade immédiate au Tier 2 / CSIRT avec demande de blocage de l'IP au niveau du firewall pfSense.
- **Conformité** : Préparation d'une notification pour le CERT-MA (délai réglementaire de 72h en cas de confirmation de fuite de données, selon les directives de Bank Al-Maghrib).



FIGURE 4 – Reconstitution de la chronologie d'attaque dans Kibana Timeline

7 Dashboards Kibana / Wazuh / Zabbix / Shuffle

La supervision visuelle est essentielle pour le monitoring continu. Voici les tableaux de bord configurés ou prévus dans l'architecture :

7.1 Dashboard Kibana SIEM

Le tableau de bord principal de l'analyste. Il affiche :

- Le nombre d'alertes actives par niveau de sévérité (Critical, High).
- Le top 5 des adresses IP sources générant le plus d'événements **failure**.
- Une vue matricielle des techniques MITRE ATT&CK détectées (T1046, T1110, T1190).

7.2 Dashboard Wazuh

Centré sur la sécurité des hôtes (DMZ). Il permet de visualiser :

- L'état de santé des agents Wazuh (Active/Disconnected).
- Les événements d'intégrité des fichiers (FIM) en temps réel.
- La répartition des alertes par règle (ex : dominance de la règle 5712 lors de l'attaque).

7.3 Perspective Zabbix (Supervision Infrastructure)

(Pré-requis et intégration prévue pour la Séance 2)

Zabbix est intégré pour assurer la supervision de la **disponibilité** et des **performances** de l'infrastructure bancaire. Contrairement au SIEM qui analyse la sécurité, Zabbix alerte sur :

- L'utilisation CPU/RAM des serveurs Web et API (détection potentielle de déni de service).
- L'état des services (Apache, Node.js, Elasticsearch).
- La disponibilité réseau (Ping, état des interfaces pfSense).

7.4 Perspective Shuffle (SOAR)

(Pré-requis et intégration prévue pour la Séance 3)

Shuffle agit comme une plateforme d'orchestration, d'automatisation et de réponse (SOAR). Il sera connecté aux webhooks de Kibana pour automatiser la réponse aux incidents P1. **Scénario d'automatisation** : Dès qu'une alerte EQL "Kill Chain" est générée → Shuffle récupère l'IP source → Appelle l'API de pfSense pour ajouter une règle de blocage (DROP) dynamique → Crée un ticket Jira pour le Tier 2.

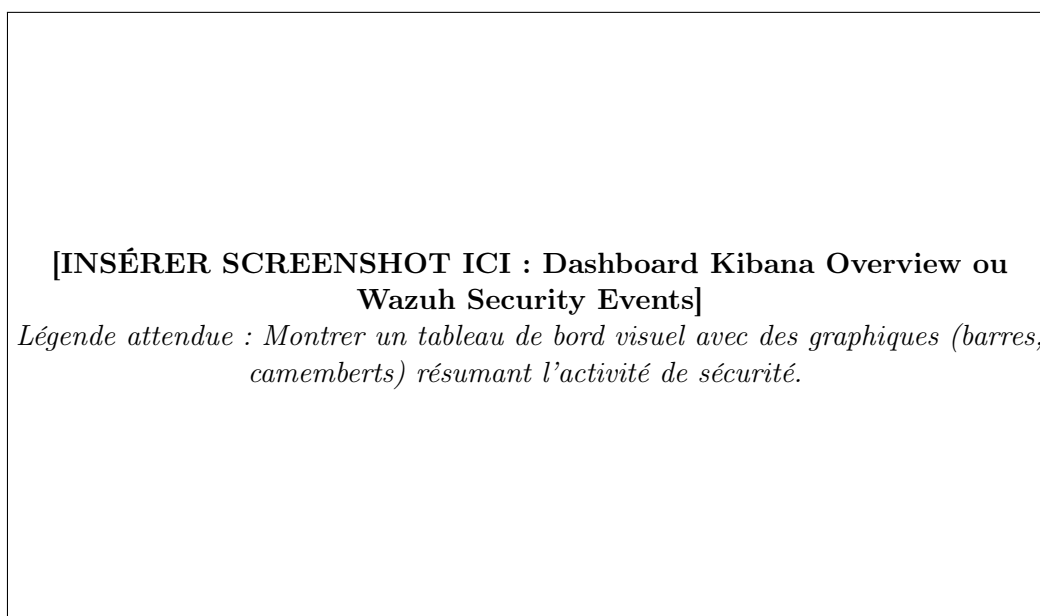


FIGURE 5 – Aperçu des Dashboards de supervision SOC

8 Conclusion

Ce travail pratique a permis de construire et d'opérer avec succès le premier niveau défensif d'un Security Operations Center pour le scénario SecureBank SA.

8.1 Bilan Technique

- L'architecture de collecte (pfSense → Filebeat/Syslog → Elasticsearch) est opérationnelle.
- La normalisation via l'Elastic Common Schema (ECS) a démontré sa valeur cruciale en permettant une corrélation transversale des logs avec une simple requête KQL.
- La règle EQL créée permet de détecter automatiquement une *kill chain* complexe en moins de 5 minutes, respectant ainsi les SLA d'un analyste Tier 1.

8.2 Leçons Apprises et Recommandations

L'analyse a confirmé l'importance du choix **IDS passif** en environnement bancaire critique : il permet d'observer et d'alerter sans risquer d'interrompre des transactions légitimes à cause de faux positifs.

Pour les prochaines séances, il est recommandé de :

1. Activer l'*Active Response* de Wazuh pour un blocage local automatique après 8 échecs SSH.
2. Affiner les règles Suricata sur une période d'observation avant de basculer en mode **IPS inline** (Séance 3).
3. Finaliser l'intégration de Zabbix pour la supervision de la disponibilité et de Shuffle pour l'automatisation de la réponse (SOAR), complétant ainsi la boucle de détection et de réponse du SOC.